CYSEC – THEORIE DOCUMENT

Cybersecurity – lesmateriaal en theorie – Versie 0.9.1

Geschreven door Erwin van Hunnik
Nova College Beverwijk 2025-2026

Inhoud

1. Cyber security algemeen 2
1.1. Beveiligingsmethodieken 2
2. Encryptie en cryptografie 3
2.1. Encryptie uit het verleden 3
2.2. Moderne encryptie 7
2.3. Digitale encryptie 9
3. Cyber awareness en aanvallen 12
3.1. Cyber awareness 12
3.2. Cyber aanvallen 14
4. Cyber wetgeving en criminaliteit 24
4.1. Internationale wetgeving 24
4.2. Europese wetgeving 26
4.3. Nederlandse wetgeving 28
4.4. Amerikaanse wetgeving 29
4.5. Chinese wetgeving 30
4.6. Contract types binnen de IT 32
4.6. Cyber criminaliteit 35
Bronnen en afbeeldinglinks 37
Handige studie links en video's 37

1. Cyber security algemeen

Cyber security is een belangrijk begrip binnen de IT wereld. Er zijn vele aspecten om naar te kijken als je het hebt over cyber security. Dit hoofdstuk geeft een introductie tot het vakgebied van cyber security.

Cyber security heeft te maken met hoe je omgaat met data, wie toegang heeft en kan krijgen Hoe je netwerken monitort en beveiligd en hoe encryptie werkt. Ook is de positie innemen van een hacker belangrijk aangezien je daardoor je de zwaktes van een eigen systeem kan ontdekken.

Binnen Cyber security is er een gezegde: er is een systeem dat onhackbaar is. Dit is waar, alle systemen zijn hackbaar op den duur. Het belangrijkste dat een bedrijf op software developer kan doen is het systeem bijwerken, verbeteren en beschermen gedurende het gebruik om zo hackers tegen te gaan.

Wetgevingen zijn ook belangrijk voor developers om kennis van te hebben. In grote bedrijven wordt een laag niveau kennis verwacht waarbij een algemeen begrip voldoende is maar voor kleine bedrijven die geen juridisch team hebben is het wel belangrijk om te weten wat wel en niet kan. Zo zijn er wetten om data van gebruikers te beschermen maar ook wetten om spionage en Cybercriminaliteit tegen te gaan.

Voor dit naleeswerk zijn de hoofdstukken als volgt opgezet. In dit hoofdstuk komen enkele globale onderwerpen aan bod. In hoofdstuk twee worden encryptie methodieken behandeld met enkele historische en digitale voorbeelden. In hoofdstuk 3 word er gekeken naar cyber awareness, aanvallen en hacking in het algemeen. In hoofdstuk 4 worden criminaliteit en wetgeving behandeld op verschillende niveaus met de meest belangrijke onderwerpen uitgelicht.

1.1. Beveiligingsmethodieken

Een van de meest voorkomende beveiligingsmethodieken is iets waar mensen dagelijks mee te maken hebben. In de vroege tijd van het internet moesten mensen voor iedere actie die ze uitvoerde op een website of systeem inloggen, dit kon snel irritant worden. Destijds maakte ze gebruik van IP-logging, het bijhouden van verbonden IP adressen en welke acties eraan gekoppeld waren. Met moderne IP adressen en systemen is dat lastiger en om die reden is de cookie uitgevonden, specifieker de JWT

JWT staat voor JSON Web Token en houdt bij voor welke website je bent ingelogd, tot wanneer je inlog duurt en soms houdt het je IP adres bij in beveiligde omstandigheden. De gebruiker hoeft niets meer te doen dan het inloggen zoals altijd, de server maakt de token aan indien de inlog correct was en koppelt het account aan de token voordat deze terug gestuurd wordt naar de gebruiker. Vanaf dan stuurt de gebruiker bij iedere actie de token met de actie op en weet de server van wie het verzoek is en naar wie die terug gestuurd moet worden.

Als de token incompleet is kan de server besluiten de token te deactiveren, dit betekent dat de gebruiker dan opnieuw moet inloggen. Dit gebeurt ook als de tijd verlopen is op de token, de server een reset heeft gehad of als de gebruiker uitlogt.

2. Encryptie en cryptografie

Encryptie en cryptografie zijn de kunsten om een stuk informatie te vervormen en door te sturen naar een lezer. Encryptie is neemt twee vormen. Om informatie geheim te houden tussen twee mensen of om informatie versleuteld te bewaren. Cryptografie is zeer oud en heeft vele veranderen doorgemaakt over de eeuwen heen om een goed beeld te krijgen van cryptografie en encryptie worden diverse manieren van encryptie uitgelicht.

2.1. Encryptie uit het verleden

Encryptie is oude kunst die al duizenden jaren bestaat om informatie over te brengen zonder dat ongewenste ogen het kunnen lezen. Over de jaren heen zijn verschillende encrypties gebruikt en uitgefaseerd om diverse redenen. Drie van de oudste zijn: Atbash, Caesar en Vigenère. Deze encrypties zijn bedoeld om informatie door te sturen en eventuele intercepties op te vangen zodat geheimen daadwerkelijk geheim blijven.

2.1.1. Atbash

Atbash wordt gezien als de eerste encryptie methodiek die gebruikt werd bij het versturen van bevelen binnen het leger tussen de hoogste officieren. De berichten werden met een omgekeerd alfabet geschreven zodat het eruit zag als onzin voor iemand die kon lezen maar niet bekend was met de encryptie. Ook in het Nederlandse alfabet kan dit toegepast worden. Een E wordt dan een V en een H wordt een S.

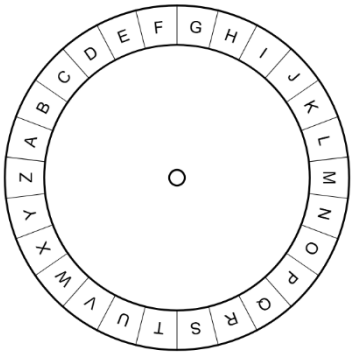
A = Z	N = M
B = Y	O = L
C = X	P = K
D = W	Q = J
E = V	R = I
F = U	S = H
G = T	T = G
H = S	U = F
I = R	V = E
J = Q	W = D
K = P	X = C
L = O	Y = B
M = N	Z = A

Een tekst zoals: Het raam staat open

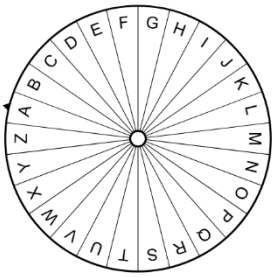
Wordt: Svg izzn hgzzg lkvm

Deze encryptie methodiek was vooral effectief omdat de algemene persoon niet kon lezen en een vijand had vaak niet genoeg kennis had over je taal om encryptie te ontdekken kon je vaak berichten op deze manier veilig versturen. De encryptie methodiek was veilig genoeg en makkelijk onhoudbaar waardoor fouten makkelijk te voorkomen waren. Echter over de vele jaren is het percentage van mensen dat kon lezen omhoog gegaan en werden er mensen in legers gebracht die de taal van de vijand konden lezen, dit heeft geleid tot het vervallen van het Atbash systeem.

2.1.2. Caesar cipher



Na Atbash zijn er enkele kleine encrypties gebruikt maar geen is zo populair geworden als het caesar cipher. Deze encryptie methodiek is niet ontwikkeld door Julius caesar maar wel populair gemaakt door hem tijdens zijn tijd in het romeinse leger. Deze encryptie methode maakt gebruik van een verschuiving van het alfabet in plaats van een gespiegeld alfabet.



Van tevoren werd er tussen de verstuurder en ontvanger een nummer afgesproken en dit vormde dan de **Key**. In zelden gevallen werd het nummer mee gestuurd met een bezorger, echter werd deze verstopt met andere middelen. Een verhaal was dat een romeinse generaal een bericht ontvangen had en de bezorger had ook 7 dadels bij zich om aan de generaal te geven, hieruit haalde de generaal dat de key 7 was. De key is de hoeveelheid posities waarin je het alfabet moet verschuiven om een geëncrypteerd bericht te maken of te ontcijferen. Tegenwoordig gebruiken we ringen die kunnen schuiven om deze berichten makkelijker te ontcijferen. De binnenste ring zijn de letters van het originele bericht en de buitenste ring het geëncrypteerd bericht.

Zo wordt de A met een verschuiving/key van 4 een E
en een G met een verschuiving/key van 9 een P

Dit maakt een tekst van: De caesar salade heeft niks te maken met Julius Caesar.

Met een verschuiving/key van: 12

In: Pq omqemd emxmpq tqqrf zuwe fq ymwqz yqf Vgxuge Omqemd.

Deze methodiek werkte goed omdat de weinige “barbaren” die Latijn konden lezen en die slim genoeg waren om Atbash te benutten zouden moeite hebben met het ontcijferen van vele (23) opties van de teksten. Over tijd werd deze methodiek zwakker omdat hoewel de methodiek enige tijd kostte om te kraken, het niet per definitie onbreekbaar was binnen een paar dagen als je de methodiek kent zonder de key.

2.1.3. Vigenère cipher

In de vele eeuwen erna zijn er enkele encryptie methodieken langsgekomen die gebruikt werden zo gebruikte de kerk en de edelheid verschillende encryptie methodes om berichten te versturen onderling. Deze waren allemaal vrij diverse en waren vaak niet consistent genoeg om altijd te werken. Bekend gemaakt door de Franse diplomaat Blaise de Vigenère maar ontworpen door de Italiaan Giovan Battista Bellaso, het Vigenère cipher was de nieuwste en veiligste methodiek om informatie te encrypteren. Vigenère gebruikte deze methodiek om berichten te versleutelen die hij verstuurde in zijn functie als diplomaat.

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
A	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
B	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A
C	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B
D	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C
E	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D
F	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E
G	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F
H	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G
I	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H
J	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I
K	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J
L	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K
M	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L
N	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M
O	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N
P	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
Q	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
R	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
S	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R
T	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S
U	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
V	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
W	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
X	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
Y	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
Z	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y

De methodiek maakt gebruikt van een soortgelijke verschuiving waarbij de sleutel in plaats van een cijfer een letter wordt. De originele vorm van de cipher had maar 1 letter maar de meest recente vorm van de encryptie gebruikt een **key** woord in plaats van een letter. Om het versleutelen en ontcijferen van de berichten makkelijker te maken wordt vaak een tabel gebruikt.

Het originele bericht wordt letter voor letter bekeken en vergelijken met de letter in dezelfde positie van de **key**. Dit bekend dat de versleuteling van het bericht complexer is dan 1 simpele verschuiving. Als de Key korter is dan het bericht dan wordt de key herhaald totdat het bericht geheel versleuteld is.

Voor een simpel voorbeeld stel dat het woord dat versleuteld wordt is: Hallo. De key die we kiezen is: Ei. Dan zoeken we de H in de kolommen en de E in de rijen en komen we op de letter L.

De tweede letter is een A en de key is een I, volgens de tabel wordt het een I.

De derde letter van het woord is L maar de key is op dus gaan we weer van voren met een E. Dit geeft een P

Na dit proces te herhalen komt het geëncrypteerd bericht: LIPTS eruit.

Deze methodiek is niet onkraakbaar. Vooral voor korte berichten is het mogelijk om handmatig zonder de key te achterhalen wat er geschreven staat. Langere berichten echter kost meer tijd en in de tijd zonder computers was het bijna onmogelijk om te achterhalen wat er geschreven stond zonder de key. Om een idee te geven van de complexiteit van de cipher, Atbash had 2 opties, Caesar had 26 opties en Vigenère had 26^N opties voor een tekst waarbij N de aantal letters in de key had.

Hoewel Vigenère tegenwoordig nog gebruikt wordt in computer systemen wordt het langzaam uitgefaseerd omdat het niet meer onkraakbaar.

2.1.4. Andere oude encrypties

Andere bekende vormen van encryptie waren rooksignalen, Symbolische substitutie, vertaling substitutie en frequency verschuivingen. Veel van deze zijn uit stijl geraakt omdat ze onbetrouwbaar waren of niet toepasbaar waren in de moderne wereld.

Rooksignalen konden vaak niet vertrouwd worden omdat ze vaak door wind en weer veranderde. Een symbolische substitutie was zeer onhandig omdat het zeer specifieke en gedetailleerde symbolen vereiste die op hetzelfde niveau eindigde als de hiëroglyfen van de Egyptenaren. Dit maakte snelle communicatie lastig. Een vertalingssubstitutie was onhandig omdat het vereiste dat vrijwel iedere mogelijke correcte ontvanger dezelfde tweede taal kende en meesterde.

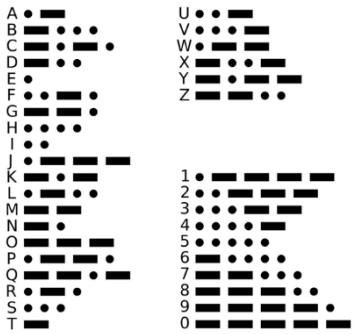
De frequency verschuiving wordt tot op zekere hoogste nog toegepast echter niet meer in de ouderwetse vorm die destijds gebruikt werd. Wel wordt het gebruikt bij het comprimeren van bestanden om ze kleiner te maken. Denk aan de bekende Zip-folders.

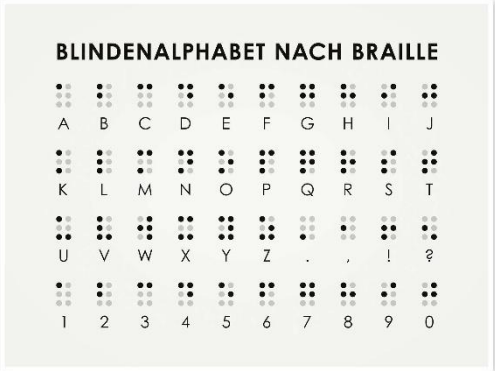
2.2. Moderne encryptie

Encryptie is niet alleen een ding van het verre verleden, de moderne tijd maakt ook gebruik van encryptie om ervoor te zorgen dat informatie overgedragen kan worden. In dit hoofdstuk worden enkele van de meest gebruikte moderne encrypties benoemd.

2.2.1. Morse code

Morse code is vrijwel een van de bekendste methodieken om iets te versturen over lange afstanden en geëncrypteerd. Deze methodiek werd gebruikt voor lange afstandscommunicatie, het leger en de scheepvaart. Morse code komt in vele vormen maar hanteert hetzelfde schema, zo wordt light, geluidstonen en elektrische signalen. Iedere letter en cijfer heeft een set van korte en lange signalen en tussen de letters en cijfers worden korte stiltes geplaatst. Deze methodiek is niet primair bedoeld om informatie geheim te houden maar om informatie te versturen wanneer gesproken of geschreven opties niet mogelijk zijn.





2.2.2. Braille

Hoewel braille niet een typische encryptie methodiek is, is het wel een vorm van encryptie. De tekst is in een vorm geschreven die voor een bepaalde doelgroep is en die voor hen toegankelijk is. Nou is het voor braille niet noodzakelijk dat een niet-blinde persoon het niet mag weten zoals bij andere encrypties. Braille is vele malen efficiënter voor blinden om te lezen dan reguliere letters aangezien het een matrix is van 2 bij 3 uitgedrukte stippen. Deze stippen kunnen dan makkelijk en snel gevoeld worden ten opzichte van grote uitgedrukte letters.

2.2.3. Numeral

Numeral is een encryptie methodiek die een numerieke waarde koppelt aan de letters Dit kan zijn dat A = 1 en B = 2 of het kan zijn dat 10 = A en 11 = B om zo 1 t/m 9 alsnog te gebruiken. Numeral heeft vele vormen en wordt veel gebruikt in computer systemen maar heeft een Europese origine in een oud Latijnse systeem dat gebruik maakte van deze encryptie. Deze encryptie was niet heel populair omdat de caesar cipher veel intuïtiever was.

2.2.4. Enigma

Enigma is een encryptie methodiek die gebruikt werd door de Duitsers tijdens de tweede wereld oorlog om berichten te versturen tussen de troepen. Het maakte gebruik van 3 tot 5 schijven die ingevoerd moeten worden met verschillende omvormingswaardes en een stekkerbord moest worden gekoppeld waardoor letters aan elkaar gekoppeld werden.

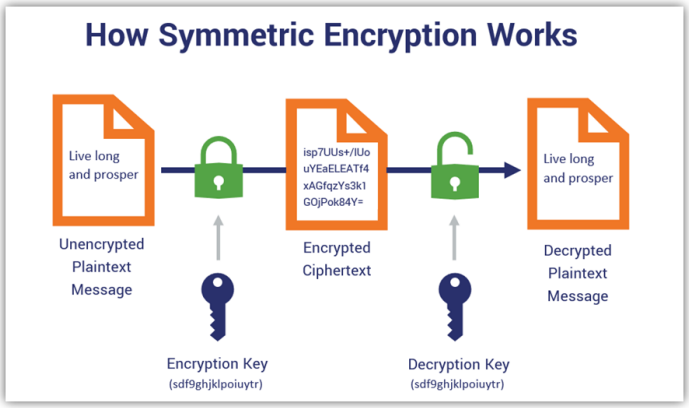
Deze methodiek was daadwerkelijk zo wiskundig complex dat het ontcijferen zonder te weten hoe het stekkerbord werd ingedeeld en welke schijven gebruikt moesten worden ervoor zorgde dat het vele dagen kosten om te ontcijferen. De grootvader van computers en robotica, Alan Turing was degene die Enigma code heeft gekraakt op hoog tempo door een computer ervoor te bouwen.

2.3. Digitale encryptie

Met de komst van computers en het internet is ouderwetse encryptie makkelijk gemaakt om te kraken. Om deze redenen zijn er diverse digitale encryptie methodieken ontwikkeld. Deze zijn specifiek bedoeld voor de communicatie tussen twee partijen die niet direct contact hebben met elkaar. Binnen de IT wereld zijn er 3 soorten encryptie: symmetrische encryptie, asymmetrische encryptie en hashing. Alle drie hebben een ander doeleinde

2.3.1. Symmetrische sleutel encryptie

Symmetrische sleutel encryptie of ook bekend als 2 richting encryptie werkt met 1 sleutel voor de encryptie en voor de decryptie. Door dezelfde sleutel te gebruiken zijn er minder kansen op fouten en worden gezien als simpele encrypties. Klassieke vormen van deze encryptie zijn de caesar cipher en Vigenère cipher maar ook het computer encryptie techniek van AES (Advanced Encryption standard).



Symmetrische encryptie is zwakker op het gebied van beveiliging omdat de sleutel op twee plaatsen beschikbaar is en dus overgedragen wordt naar iedere gebruiker, ook de kwaad-bedoelende gebruikers. Waar symmetrische encryptie vooral belangrijk kan zijn is voor communicatie die snel moet zijn. Het encrypten en decrypten van berichten met een symmetrische encryptie is vele malen sneller en kan handig zijn voor interne systemen die lage veiligheid vereisen. Denk hierbij aan de encryptie die wordt gebruikt voor publieke posts op een website of berichten tussen twee mensen waarvan gelekte informatie geen schade zou creëren.

De keys van symmetrische encryptie zijn vaak makkelijk te maken en worden vaak simpel gehouden. Bij gebruik in systemen is het zeer belangrijk dat je als ontwikkelaar rekening houdt met de zwakte/sterkte van de key. Maak geen Key aan die korter is dan 10 karakters aangezien net als bij wachtwoorden, deze kortere makkelijk te kraken zijn. Bij twijfel of de communicatie cruciaal of geheim moet blijven van derde partijen, gebruik dan bij voorkeur een asymmetrische encryptie.

2.3.2. Asymmetrische sleutel encryptie

Asymmetrische sleutel encryptie of 1 richting encryptie maakt gebruik van 2 sleutels waarvan de encryptie sleutel publiek bekend is en de decryptie sleutel geheim bij de ontvanger. Deze methodieken maken gebruik van diverse wiskundige principes en algoritmes om ervoor te zorgen dat ook met de kennis van het algoritme en de publieke sleutel je het bericht niet kan ontcijferen. Vele van de moderne digitale encryptie methodieken werken op deze principes. Hoewel sommige zijn gekraakt zijn het merendeel nog steeds veilig. Enkele voorbeelden hiervan zijn: RSA, DSA en ECC

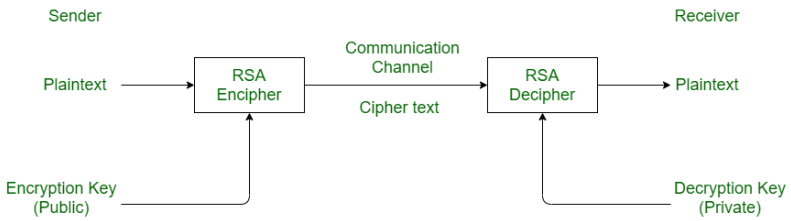
Asymmetrische sleutel encryptie is veiliger dan symmetrisch maar wel langzamer door de vele calculaties die gemaakt moeten worden. De communicatie die met een dergelijke encryptie gemaakt wordt zijn vaak privé berichten en interne communicatie op het gebied van financiën en handel. Ook de regering maakt gebruik van asymmetrische encryptie voor interne communicatie.

2.3.2.1. RSA

RSA is één van de bekendste vormen van asymmetrische cryptografie. RSA is vernoemd naar de bedenkers Rivest, Shamir en Adleman en wordt sinds 1977 gebruikt. Het algoritme maakt gebruik van twee verschillende sleutels: een publieke sleutel en een private sleutel. De publieke sleutel mag vrij gedeeld worden en wordt gebruikt om gegevens te versleutelen. De private sleutel blijft geheim en wordt gebruikt om de gegevens weer te ontsleutelen.

De veiligheid van RSA is gebaseerd op een wiskundig probleem dat moeilijk op te lossen is, namelijk het ontbinden van een groot getal in twee priemfactoren. Bij het genereren van sleutels worden twee zeer grote priemgetallen gekozen. Deze worden met elkaar vermenigvuldigd, waardoor een groot samengesteld getal ontstaat. Hoewel het vermenigvuldigen zelf eenvoudig is, is het achteraf extreem moeilijk om te achterhalen welke twee priemgetallen zijn gebruikt wanneer het getal groot genoeg is (bijvoorbeeld 2048 bits). Dit principe vormt de basis van de beveiliging.

Wanneer iemand een bericht wil versturen, gebruikt die persoon de publieke sleutel van de ontvanger om het bericht te versleutelen. Het versleutelde bericht kan vervolgens veilig over het internet worden verstuurd. Alleen de ontvanger beschikt over de bijbehorende private sleutel en kan daarmee het bericht weer leesbaar maken. RSA wordt onder andere gebruikt bij beveiligde internetverbindingen zoals HTTPS en bij het uitwisselen van sleutels in beveiligingsprotocollen.



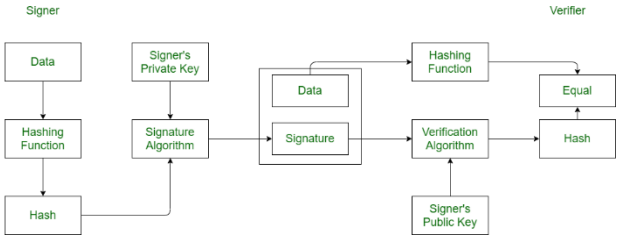
Een nadeel van RSA is dat het relatief veel rekenkracht nodig heeft, vooral bij langere sleutels. Tegenwoordig worden meestal sleutels van minimaal 2048 bits gebruikt om voldoende veiligheid te garanderen. Dit maakt RSA minder efficiënt dan modernere technieken zoals ECC, maar het blijft een veelgebruikte en goed onderzochte standaard.

2.3.2.2. DSA

Digital Signature Algorithm is een algoritme dat speciaal ontworpen is voor digitale handtekeningen. In tegenstelling tot RSA wordt DSA niet gebruikt om gegevens te versleutelen, maar uitsluitend om de echtheid en integriteit van een bericht te controleren. Het algoritme werd ontwikkeld als onderdeel van een Amerikaanse standaard voor digitale beveiliging.

Bij DSA wordt eerst een hash-functie toegepast op het bericht. Een hash-functie zet een bericht om in een vaste, korte reeks cijfers en letters. Deze hash is uniek voor de inhoud van het bericht.

Als er ook maar één teken in het bericht verandert, verandert de hash volledig. Veelgebruikte hash-functies zijn bijvoorbeeld SHA-256.



Na het berekenen van de hash wordt met behulp van de private sleutel een digitale handtekening gemaakt. Deze handtekening is gekoppeld aan zowel de inhoud van het bericht als aan de geheime sleutel van de verzender. De ontvanger kan vervolgens met de publieke sleutel controleren of de handtekening geldig is. Als de berekende controle overeenkomt met de ontvangen handtekening, weet de ontvanger dat het bericht niet is aangepast en daadwerkelijk afkomstig is van de juiste afzender.

De veiligheid van DSA is gebaseerd op het zogenaamde discrete logaritmeprobleem, een wiskundig probleem dat zeer moeilijk op te lossen is bij grote getallen. Een belangrijk aandachtspunt bij DSA is dat het algoritme afhankelijk is van goede willekeurige getallen tijdens het ondertekening proces. Als deze willekeurigheid niet goed wordt gegenereerd, kan de private sleutel worden achterhaald.

DSA wordt tegenwoordig minder vaak zelfstandig gebruikt, maar het principe van digitale handtekeningen is nog steeds een essentieel onderdeel van moderne beveiligingssystemen.

2.3.3. Hashing

Hashing is een encryptie methodiek die het alleen bedoeld is voor encryptie en niet voor decryptie. Deze methodiek is vooral gebruikt bij het opslaan van wachtwoorden in een database. De theorie achter hashing is dat een systeem gebruik maakt van een Seed, dit is een reeks cijfers en letters die het hashing algoritme gebruikt om de ingevoerde tekst te wijzigen naar een lange string met karakters. Het voordeel van hashing is dat ook al is de Seed bekend en het opgeslagen wachtwoord dan kan de hacker alsnog niet concreet een wachtwoord achterhalen omdat er meerdere inputs dezelfde hashed wachtwoord zouden kunnen genereren.

Een ander voordeel van hashing is dat het snel werkt omdat er geen rekening gehouden hoeft te worden met een decryptie methodiek. Het enige “onveilige” aan hashing is dat de Seed vaak publiekelijk beschikbaar is wat als effect heeft dat hackers vaak pogingen zullen doen om de hashing te doorbreken met de Seed.

Deze techniek zorgt ervoor dat mensen veilig en consistent in kunnen loggen met hun wachtwoord en hoeven ze het wachtwoord niet over te sturen in een omdraaibare encryptie. De meeste bekende hashing methodieken zijn: de SHA series (SHA1 en 2 zijn in de tussentijd niet veilig meer maar SHA3 wel), de BLAKE series en de Bycrypt methodiek.

SHA3 wordt wijd gebruikt en bij lagere onbelangrijke systemen wordt SHA2 nog gebruikt. Liggend aan de noodzaak voor veiligheid kan er gekozen worden voor een SHA2 encryptie. Het merendeel van de programmeertalen heeft een standaard functie voor SHA2 en/of SHA3 of er is een package/library beschikbaar die makkelijk geïmplementeerd kan worden ervoor.

3. Cyber awareness en aanvallen

In dit hoofdstuk worden de twee cyber concepten toegelicht en worden de belangrijkste elementen uitgewerkt, Cyber awareness en cyber aanvallen. Cyber awareness richt zich op het bewust worden van je omgeving en eigen handelen terwijl cyber aanvallen de meest voorkomende aanvallen uitlicht.

3.1. Cyber awareness

Cyber beveiliging is niet alleen computers maar ook de beveiliging om je heen en de gewoontes die je hebt. Hierin spelen je wachtwoorden een rol maar ook de fysieke veiligheid van jezelf en apparatuur

3.1.1. Wachtwoord veiligheid

Wachtwoord veiligheid is de nummer 1 reden waarom je mensen hun account kwijt raken. Dit kan zijn omdat een wachtwoord makkelijk te raden is, omdat een wachtwoord te kort is of omdat een wachtwoord gelekt is.

Ieder jaar wordt de wachtwoord richtlijnen opnieuw bekeken om te kijken hoe snel een wachtwoord met brute kracht gekraakt kan worden. Deze richtlijnen bepalen of je wachtwoord zwak is of sterk. De richtlijnen houden vaak ook rekening met een hashing encryptie en 1 server unit aan kracht wat redelijk normaal is voor een gerichte brute force kraak.

Deze richtlijnen houden echter alleen rekening met de complexiteit van een wachtwoord niet hoe vaak die in de wereld gebruikt is.

Time it takes a hacker to brute force your password in 2025

Hardware: 12 x RTX 5090 | Password hash: bcrypt (10)

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	57 minutes	2 hours	4 hours
6	Instantly	46 minutes	2 days	6 days	2 weeks
7	Instantly	20 hours	4 months	1 year	2 years
8	Instantly	3 weeks	15 years	62 years	164 years
9	2 hours	2 years	791 years	3k years	11k years
10	1 day	40 years	41k years	238k years	803k years
11	1 weeks	1k years	2m years	14m years	56m years
12	3 months	27k years	111m years	917m years	3bn years
13	3 years	705k years	5bn years	56bn years	275bn years
14	28 years	18m years	300bn years	3tn years	19tn years
15	284 years	477m years	15tn years	218tn years	1qd years
16	2k years	12bn years	812tn years	13qd years	94qd years
17	28k years	322bn years	42qd years	840qd years	6qn years
18	284k years	8tn years	2qn years	52qn years	463qn years

Hive Systems

Read more and download at hivesystems.com/password

Hiervoor kan je het beste kijken naar de top 100 lijst van wachtwoorden gebruikt over de hele wereld en bij twijfel kan je via https://haveibeenpwned.com/Passwords nagaan of je wachtwoord al op straat ligt en of deze veel gebruikt wordt.

3.1.2. Vergetelheid en databrokers

Veel van onze data is in handen van bedrijven echter kunnen minder betrouwbare figuren toegang krijgen tot jouw data op 2 manieren: ze kopen gehackte data of ze kopen via derde partijen jouw data en gebruiken dit weer voor slechte doeleindes.

Deze data kan onschuldig zijn maar kan ook tot gevolgen leiden van afpersing of tot identiteitsfraude. Wees daarom dan ook bewust wat je waar deelt. Niet zomaar je ID versturen naar een bedrijf dat dit niet nodig heeft.

Om dit tegen te gaan kan je een verzoek doen tot vergetelheid. Dit verzoek zorgt ervoor bedrijven jouw data moeten verwijderen die niet cruciaal is tot jouw bestaan als klant/gebruiker of om je af te sluiten en dan de data te deleten. Door dit regelmatig te doen kan je jouw data vaak uit handen houden van criminelen. Het enige nadeel is dat dit vaak veel tijd kost. Hier zijn diensten voor online die dit geautomatiseerd voor je regelen maar kosten vaak een maandelijks bedrag.

3.1.3. Fysieke Beveiliging

Fysieke beveiliging kan ook een rol spelen in cyber awareness. Dit neemt de rol in van de beveiliging van een bedrijfsingangen, maar ook de omgeving van programmeurs en hun apparatuur.

Een vaak voorkomend ongeval is dat de laptop of pc van een systeembeheerder onbemand ergens ligt zonder dat deze vergrendeld staat. Een aantal Google engineers heeft zo een beveiligingsschandaal gecreëerd door hun laptops te laten liggen in een lokaal café terwijl ze koffie aan het halen waren.

Een ander voorbeeld is hoe als code panelen in het open zichtbaar zijn dat mensen in de directe omgeving kunnen zien welke code wordt ingetoetst en deze dan kunnen benutten om toegang te krijgen tot een gebouw.

Veel social engineering technieken worden in combinatie met fysieke beveiligingsproblemen gebruikt om een aanval uit te voeren.

3.2. Cyber aanvallen

Er zijn vele soorten aanvallen die gedaan kunnen worden op een systeem. Denk aan databases hacken, social engineering en netwerk aanvallen maar ook aan types kwaadaardige software

3.2.1. Brute forcing

Brute forcing oftewell password cracking oftewell een van de oudste cyber aanvallen in de cyber geschiedenis. Brute forcing zegt niks anders dan het forceren van het juiste wachtwoord door alle variaties van letters(Zowel groot als klein), cijfers en tekens er tegen aan te gooien. Dit kunnen simppelen programmas zijn die beginnen met “0000000” en wijzigen 1 symbool totdat ze een wachtwoord hebben dat werkt. Complexere brute force algoritmes houden rekening met wachtwoord eisen en controleren eerst de meest voorkomende wachtwoorden.

3.2.2. Cyber aanval software en virussen

Binnen de IT spreken we over 3 soorten cyber aanval software en een hand vol virussen die veel schade kunnen aanrichten op een systeem.

Software

Binnen de cyber aanval software zijn er 3 die het meeste voorkomen: Malware, Ransomware en spyware.

Malware (malicieus software) is een kwaadaardig programma dat de intentie heeft om data te corrupten en/of verwijderen. Dit zorgt ervoor dat een systeem niet meer kan werken en dan mogelijk zwakker wordt en meer toegang kan geven. Binnen Malware spreken we van general malware voor een sloopprogramma, elke file is een doelwit. Dit is anders dan targeted malware waarbij het programma op zoek is naar specifieke files om te breken. Dit zijn dan vaak belangrijke files met data of files die een beveiligingssysteem nodig heeft om te functioneren.

Ransomware (losgeld software) is een programma dat de beveiliging en controle van een computer deactiveert en dan de toegang van het systeem blokkeert totdat of de computer opnieuw geïnstalleerd wordt of tot het losgeld betaalt wordt. Sommige oudere ransomware zijn in de tussentijd eerder scareware geworden aangezien ze makkelijk omzeild kunnen worden door een secure/safe boot echter de moderne ransomware is een stuk efficiënter.

Spyware komt in diverse vormen, het kan een programma zijn dat enkel specifieke bestanden observeert, zoekgeschiedenis observeert of zelfs de camera ongemerkt aanzet om een gebruiker te bespioneren. Tussen 2005 en 2008 waren enkele camera spywares heel erg in gebruik met als doelwit jongeren. Om dit probleem op te lossen zijn moderne laptops vaak gemaakt met een schuifje die je toelaat om een camera hardware matig te ontkoppelen of waarbij er een plaatje voor geschoven kan worden om opnames tegen te gaan. Een modern voorbeeld van een hoog niveau spyware middel is de Israëlische Pegasus.

Virussen en soort gelijke programma's

Binnen de groep van virussen horen uiteraard het standaard computer virus dat bedoeld is om data te corrupten echter is dat niet het enige dat een virus kan doen. Ook zijn er andere kleinere programma's die kunnen draaien die schadelijk zijn voor je systeem.

Het Trojaans paard is een bekende aanvalstactiek die bekend werd in Griekse mythologie. Later bleek het verhaal van Troje en de vermomde gift echt te zijn gebeurt. Dit paard is de inspiratie geworden van vele dingen, zo is er een nachtclub ernaar vernoemd, een attractie in toverland maar ook een programma dat zich vastplakt aan een legitiem document maar bij openen activeert dit programma en kan het een achterdeur openen voor zwaardere schadelijke software

Een zombie virus is naast een welbekend fictieve horror onderwerp ook een type virus dat zich vast maakt aan een computer en langzaam in de achtergrond de controle overneemt. Dit is kenmerkend aan de muis die beweegt of dat toetsen worden ingedrukt zonder input van de gebruiker. Dit kan om verschillende redenen ingezet worden echter is de meest bekende reden om een open deur te creëren voor andere kwaadaardige programma's.

In sommige gevallen zijn er meerdere zombies die samenwerken via een meester programma. Dit wordt vaak een botnet genoemd. geïnfecteerde computers kunnen tegelijk gericht worden op een doelwit en er een aanval op uitvoeren zoals een DDOS aanval.

De laatste en niet minste belangrijke kwaadaardige programma wordt vaak in combinatie gebruikt met de andere. Het gaat om een worm programma. Dit programma infecteert 1 computer en maakt zich vast aan dat systeem, vervolgens gaat deze worm bij het eerste de beste netwerk op zoek naar ongeïnfecteerde systemen en brengt daar ook een worm op aan. Deze verspreiden zich totdat er geen enkel systeem niet geïnfecteerd is.

3.2.3. Social engineering

Social engineering kan ook sociale hacking genoemd worden, denk hierbij aan manipulatie en overtuigingen maar ook veel meer. In dit hoofdstuk worden de meest voorkomende technieken toegelicht.

Phishing

Phishing is het trekken van mensen via een communicatie middel en je voordoen als iemand anders om met vertrouwen informatie of toegang te winnen. Dit kan zijn omdat de email aangeeft dat je iets gratis hebt gewonnen, je account in gevaar is zonder je actie of dat je familielid op vakantie was maar geen telefoon, pinpas of paspoort meer heeft.

Binnen phishing zijn er nog enkele specifieke subtypes:

Spear phishing is waarbij de phishing doelgericht wordt toegepast en niet heel breed is gesteld. Denk hierbij aan een phishing email die specifiek zich voordoet als een geliefde van jou met enige kennis over jou en die geliefde om zo informatie te winnen of toegang te krijgen tot een systeem.

Whaling is waarbij het doelwit niet alleen specifiek is maar ook vaak veel geld of macht heeft. Denk hierbij aan een CEO of een bekendheid.

Vishing is het phishen met je gebruik van je stem, denk hierbij aan het bellen met de telefoon.

Smishing is het phishen doormiddel van SMS berichten

Angler phishing is het phishen via een bekende website die vertrouwd is maar daar achter zit de scam elementen.

Ad Phishing is het plaatsen van een advertentie die te mooi om waar te zijn of lijken op legitieme advertenties maar de link leidt niet naar de officiële website maar een scam versie ervan.

Van alle vormen van social engineering is dit de makkelijkste om uit te voeren en om te spotten. Hieronder is een overzicht van de kenmerken en hoe sommige verborgen kunnen worden in een phishing aanval

Vindbare kenmerken	**Verbergings tactieken**
Slecht taalgebruik	Spellingschecker of AI
Incorrect email adres	Email spoofing (het laten lijken dat een email vanuit een ander email adres komt)
Niet kloppende aanhef of afsluiting	Enig email contact van tevoren om stijl en structuur te kopiëren
Links komen niet overeen met wat er staat in de email	Tinyurl, url spoofing, url masking en meer.
Onnodige druk (High importance emails)	Gepaste toon stellen en goed met woorden zijn
Geen details van doelwit of gebruikte persoon	Meer onderzoek doen
Vreemde timing van email	Inplannen volgens lokale tijd van doelwitten (bij voorkeur net buiten werktijd of net voor het weekend)
Email beland in spam/ongewenste mails	-

Baiting

Baiting is een klassieke techniek waarbij de hacker zich voordoet als een ongelukkig iemand die zijn/haar USB kwijt is geraakt in een café of bedrijf. Vervolgens vindt een doelwit deze usb en om diverse redenen zal deze de usb in de computer doen. Bij invoer van de usb kan de usb een programma activeren die een virus of andere software op de computer zet, hierna wordt het systeem benut voor de hacker.

Tailgating

De hacker moet toegang krijgen tot een systeem of ruimte maar heeft geen sleutel. De hacker wacht tot er een doelwit richting de deur loopt die wel een sleutel heeft en loopt stilletjes mee met het doelwit. De hacker is nonchalant of doet alsof deze er naar binnen moet omdat deze daar hoort te zijn. Veel hackers proberen dan ook een reden te vinden om niet zelf de deur open te maken, denk hierbij aan handen vol of gebroken pasje.

Pretexting

Pretexting is de kunst van een verhaal zo maken dat het emoties opwekt bij het doelwit zodat deze meegaander is. De meest voorkomende emoties zijn empathie, stress, zelfvernedering en verdriet. Dit werkt heel goed als de hacker enige acteer skills heeft. Een goed verhaal kan het doelwit een reden geven om de regels meer los te laten om de hacker te helpen.

Quid pro quo

Quid pro quo is latijn voor Ik doe wat voor jou en jij voor mij, vaak verkort tot voor wat hoort wat. Vaak maken hackers gebruik van de tekortkomingen van een doelwit om zo informatie te winnen, denk hierbij aan geld zorgen, verslavingen en relatieproblemen.

Een hacker zal eerst proberen zich een plekje te maken binnen de sphere of influence van het doelwit, dit is de omgeving van het doelwit waar de hacker invloed kan uitoefenen.

Een uitgebreid voorbeeld kan zijn: Een hacker die weet dat een systeem beheerder relatieproblemen heeft. Deze zal dan toevallig in een bar de beheerder tegenkomen en uitnodigen voor een drankje en gezellig babbelen. Ze raken bevriend door (gespeelde) overeenkomende interesses. Ze spreken vaker af en worden hechter. De hacker vraagt naar wat de beheerder voor werk doet en vraagt om het te zien. De hacker laat het systeem via zijn/haar thuislaptop zien en sluit het programma, maar niet de laptop af om koffie te maken. De hacker stopt een spyware op de laptop en heeft vanaf dan toegang tot het systeem.

Een ander voorbeeld is een vaak directere aanpak, de beheerder krijgt geld toegestoken een paar keer voor onzinnige redenen, en later krijgt de beheerder het verzoek om toegang te verlenen of specifieke data te stelen voor een groter bedrag.

Machtsmisbruik

Deze tactiek wordt niet vaak gebruikt vanuit buitenaf maar wel vanuit het bedrijf zelf. Et is vaak voorgekomen dat sommige medewerkers gebruik willen maken van financiële documenten van

gebruikers/klanten om zo fraude of identiteitsdiefstal te plegen. Om dit doel te bereiken leggen ze druk op de beheerder of ontwikkelaar om zo toegang of data te verkrijgen.

Scareware

Scareware lijkt heel erg op ransomware maar is dit niet. Scareware is een programma dat een pop-up opent met een gevaarlijk uitziende melding dat het systeem geïnfecteerd is. Hierbij staat dan dat de beveiligingssoftware geüpdatet moet worden om hiervan af te komen met een duidelijke knop om te updaten. Dit brengt de gebruiker naar een website die er legitiem uit ziet maar dit niet is. de gebruiker update niet de beveiliging maar installeert een daadwerkelijk virus of ransomware. De reden dat dit social engineering is en niet een aanval is omdat het meer focust op de mens en diens reacties dan om een technische aanval.

Diversion theft

Diversion theft is het stelen van fysieke pakjes of post door je voor te doen als een bewoner van een pand of medewerker van een bedrijf zonder dit te zijn.

Bijvoorbeeld de hacker ziet de postbode in de straat van het doelwit aankomen en loopt naar de deur en doet alsof deze de deur op slot draait, draait zich om naar de postbode en zegt iets zoals “Ow is dat de post, net op tijd voor ik op bezoek naar mijn ouders ga, kom maar, scheelt jou werk”

Postbodes in Nederland worden ook gevraagd om niet pakjes en post aan mensen te geven tenzij ze na het bellen iemand uit het huis zien komen. Dit wordt niet altijd nageleefd.

Watering hole / Common grounds

Als een aantal van de doelwitten van een hacker bij een gemeenschap horen dan zal de hacker die gemeenschap proberen te betreden en via daar toegang of informatie te winnen, dit kan op twee vergelijkbare manieren

Watering hole is waarbij de doelwitten van bedrijf A ook voor een deel fan zijn van website M. de hacker wil toegang tot bedrijf A maar de beveiliging is te hoog maar website M heeft slechte beveiliging. Om toegang te krijgen hackt de hacker in website M waar een virus of software vermomd wordt als legitiem en verspreid zich zo door via de systemen van de medewerkers naar het netwerk van Bedrijf A. Deze techniek is bijna hetzelfde als angler phishing maar niet hetzelfde.

Common grounds heeft eenzelfde begin: medewerkers van bedrijf A zijn fan van website M. De hacker doet ook mee met website M en maakt vriendelijk contact met de medewerkers. Na veel gesprekken overtuigd de hacker een van de medewerkers een nieuw programma te proberen dat ze hebben ontwikkeld om een mening te ontvangen. Dit programma bevat een virus of andere software. Tegen de tijd dat het ontdekt is, heeft het zich al verspreid of zijn doel bereikt.

Covert espionage

Covert espionage is een breed begrip waarbij er veel onder komt te vallen. Denk hierbij aan vermommingen, achtervolgingen, veel observaties, aanvals- en infiltratieplannen en vaak inbreken. Hoe uitgebreider hoe specifieker de doelwitten vaak zijn. De James Bond en Mission Impossible films zijn, hoewel niet accuraat en hyperbolisch gefilmd wel, deels te vergelijken met dit deel van het werkveld.

De psychologie erachter

Veel mensen vallen voor deze technieken niet omdat ze dom zijn maar omdat het menselijk is om elkaar te geloven. De meest voorkomende redenen zijn:

Autoriteit - iemand met gezag heeft meer invloed en kan meer winnen uit een ander dan iemand die dat niet heeft. Dit hoeft niet per definitie een hogere positie binnen het bedrijf te bekekenen. Een hacker kan een CEO weten te pakken terwijl deze zich voordoet als een IT medewerker. De IT medewerker heeft namelijk meer gezag over het IT systeem dat de CEO gebruikt dan de CEO, dus meer vertrouwen dat het klopt.

Urgentie – Als een doelwit het gevoel heeft dat er haast achter zijn/haar acties zit dan zal deze minder nadenken over wat de acties daadwerkelijk betekenen.

Angst – als een doelwit bang is of angstig wordt van de vermeende angst van de hacker dan worden logische gevolgen kleiner. Denk hierbij aan het verliezen van account controle of verliezen van geld op de rekening.

Hebzucht/gierigheid – Geld maakt iedereen gelukkig als het makkelijk te krijgen is, dit maakt sommige mensen zo blind dat ze niet zien dat wat ze prijsgeven vaak meer waard is.

Behulpzaamheid – het is een natuurlijke reactie om iemand die hulp nodig heeft te helpen. Dit gebruiken hackers door vaak meerdere grotere problemen in het gesprek te verweven waar het doelwit niet bij kan helpen en dan iets te noemen dat wel kan helpen. Dit geeft de hacker vaak een moment waarbij deze de toegang kan krijgen tot een systeem die ze nodig hebben.

3.2.4. Netwerk beveiligen, monitoren en aanvallen

Een netwerk is een connectie tussen 2 of meer entiteiten, binnen de IT-wereld hebben we het dan over 2 of meer computers. Binnen de netwerken hebben we 3 basis netwerken waar we over spreken, Direct, Kabelnetwerken en draadloze netwerken

Directe netwerken komen niet veel meer voor en zijn twee computers die tegen elkaar praten, vaak via 1 kabel.

Kabelnetwerken zijn netwerken waarbij alle computers op hetzelfde internet zijn verbonden via dezelfde kabel. Dit wordt vooral gebruikt voor 1 gebouw bedrijven met een intranet.

Draadloze netwerken zijn netwerken die via wifi en 5G draaien, sommige hebben beveiligde draadloze netwerken zoals een VPN en sommige draaien op het brede internet.

Binnen dit hoofdstuk bespreken wel enkele manieren om een netwerk aan te vallen, beschermen en monitoren.

Netwerk aanvallen

Een netwerk kan op diverse manieren aangevallen worden en om diverse redenen, soms is informatie winnen al genoeg maar soms is de doelstelling om een systeem plat te leggen. Om een globaal beeld te krijgen van de diverse aanvallen worden de meest voorkomende aanvallen in 5 categorieën beschreven.

Blokkades/weigeringsaanvallen

Blokkades en weigeringsaanvallen zijn bedoeld om de communicatie tussen een server en de eindgebruikers te beïnvloeden. Dit wordt voornamelijk gedaan door 3 methodieken: DDOS, volume bezetting en malafide geformatteerde pakketten

DDOS is de meest bekende aanval van alle grootschalige aanvallen. Dit is waarbij een hacker de servers bombardeert met verzoeken totdat de server het niet meer aankan en crasht.

Volume bezetting is de slappere techniek van DDOS, waarbij de communicatie bijna vol gegooid wordt zodat de daadwerkelijke berichten niet goed of allemaal bij de server eindigen maar niet zo vol gegooid dat het crasht

Malafide geformatteerd pakketten zijn aanvallen waarbij expres foutieve geformatteerd berichten worden ingestuurd zodat een server moet verlangzamen en dus niet optimaal kan functioneren

Toegangsaanvallen

Toegangsaanvallen zijn bedoeld om toegang te winnen binnen een systeem. Twee bekende voorbeelden van een dergelijke aanval is IP spoofing, waarbij de hacker zich voordoet als een vertrouwde IP adres om toegang te krijgen tot een netwerk en man in the middle. Man in the middle (ook bekend als packet sniffing) is waarbij de hacker het netwerk loopt af te luisteren voor sleutels, verificaties en cruciale gegevens die van en naar een server gaan. Dit kan dus ook gebruikt worden om de inloggegevens van een doelwit op te vangen en gebruiken.

Onderzoekende aanvallen

Deze aanvallen kijken naar eventuele openingen die gebruikt kunnen worden bij een grotere aanval. De bekendste tactiek hiervoor is pingen/port sweeping. Deze techniek kijkt naar welke apparaten en porten een open connectie hebben die niet beveiligd is. als er een reactie komt van de ping dan weet de hacker dat dit een connectie is die benut kan worden.

Afluisteringsaanvallen

Afluisterende aanvallen zijn aanvallen waarbij informatie winnen van belang is. dit kan ook een man in de middle zijn maar vaker bij een slecht netwerk wordt hier gebruik gemaakt van een IP spoof. Dit zorgt ervoor dat de hacker hetzelfde IP adres maakt als het doelwit en dus alle berichten ontvangt die het doelwit ook zou krijgen.

Slopende aanvallen

Slopende aanvallen zijn aanvallen waarbij de doelstelling is om een netwerk te breken. Een bekende aanval hierbij is een buffer overflow aanval. Hierbij worden herhaaldelijk errors gegenereerd op een server totdat deze zonder geheugen zit. Hierna eet het systeem een deel van zijn eigen code op en opent een gat voor de hacker.

Een aantal van de bekendste technieken

De wifi in de trein techniek. Een hotspot aanmaken met de naam wifi in de trein, en dan afluisteren welke mensen inloggen op hun accounts.

De koffieshop techniek: cafés over de hele wereld hebben vaak een lokale wifi met geen of een publiek wachtwoord. Dit zorgt ervoor dat een hacker makkelijk op het netwerk kan en dan kan afluisteren wie waar op inlogt. Starbucks is vaak een bekend doelwit geweest totdat ze een beveiligingseis hebben gesteld op hun winkels.

Netwerken beschermen

Om een netwerk te beveiligen kan je vaak kijken naar 4 invalshoeken: connectie, toegang, ongeautoriseerde data en data extractie.

Door de connectie met een netwerk te beveiligen kan je controleren dat iedereen die op dat netwerk zit daadwerkelijk er hoort te zijn. Dit kan al verbeterd worden door een sterk wachtwoord in te zetten.

Door de toegang tot systemen binnen het netwerk te beveiligen en controleren kan een hacker die op de verbinding zit minder schade doen.

Door inzicht in data te beveiligen met een autorisatie controle kunnen mensen die specifieke data moeten inzien dit alsnog doen maar mensen die dit niet horen te kunnen doen dit niet.

Door data extractie te limiteren of verbieden kan een hacker (bijna) geen data winnen in de tijd die ze hebben voordat ze gevonden worden.

Thuis netwerk beveiligen

Bedrijven zijn niet de enige die doelwitten zijn van netwerk aanvallen, thuis netwerken zijn ook doelwitten. Om dit te beveiligen zijn er enkele stappen die gezet kunnen worden.

- Zorg voor een WPA3 versleuteling, WPA2 is voor de komende 2 tot 5 jaar nog voldoende maar daarna waarschijnlijk niet. WPA is niet voldoende meer.
- Maak een splitsing tussen privé en publieke netwerken, hierdoor kan een gast gebruik maken van je internet maar geen risico vormen voor je privé netwerk.
- Een beveiligd netwerk dat toegang verleend aan alle apparaten via een fysieke aansluiting is niet veilig, zorg ervoor dat ook fysieke aansluitingen een wachtwoord vereisen
- Sterke geheime wachtwoorden zijn een vereiste, dit blokkeert ongeveer 70% van de prive dreigingen.
- Iedere router moet een firewall in
- VPNs zijn zeer nuttig en beschermen je netwerk en internet gebruik maar zijn niet perfect.
- Internet verleners (telecom) bedrijven houden vaak data vast over je internet gebruik, dit geldt ook voor je zoek resultaten. In Nederland kan je een formeel verzoek doen tot verwijdering van je data geschiedenis bij een provider (Recht op vergetelheid, artikel 17 van de AVG). Dit forceert bedrijven om niet essentiële data te verwijderen van hun databases en servers. Als je om essentiële data vraagt kan het zijn dat ze het contract dan ontbinden.

Netwerken monitoren

Netwerken monitoren doen zowel de hackers als systeembeheerders, beide maken gebruik van software die ervoor bedoeld is, het gebruik ervan echter zijn compleet anders.

Hackers gebruiken de software vaak om informatie te winnen, denk aan de toegang van systemen maar ook cruciale informatie voor chantage, bedrijfsgeheimen die de markt kunnen beïnvloeden, ruwe data die verkocht kan worden op de zwarte markt of zwaktes omhoog brengen voor een volgende aanval.

Spysoftware is meestal makkelijk te herkennen en heeft net als een ziekte een aantal symptomen. Denk hierbij aan camera's die aan of uit gaan zonder input, muis of toetsenbord inputs die niet door de gebruiker gebeuren. Deze symptomen zijn heel duidelijk en zichtbaar echter andere symptomen zijn dat niet altijd. Een computer die zonder reden warmer wordt, langzamer wordt of op standby/zwart scherm gaat kunnen ook signalen zijn van spyware.

Een tip om mee te nemen, spyware is vaak zichtbaar in task manager en de slimme spyware zal monitoren het openstaan van task manager en zetten zichzelf uit als task manager open staat om te voorkomen dat ze gevonden worden.

Systeem beheerders maken ook gebruik van monitoring software om een hacker te spotten die op een netwerk zit, deze software laat ze toe om het IP adres te vinden en ze van het netwerk af te halen.

Een versimpelde versie van een dergelijk monitor programma is Wireshark.

3.2.5. Databases en data aanvallen

Een database bevat veel data en niet iedereen hoort hier toegang tot te hebben, vooral geen hackers. Om deze buiten te houden moet een systeem beheerder en ontwikkelaar vaak kennis hebben op het gebied van welke aanvallen en verdedigingen er zijn. In dit hoofdstuk worden enkele van deze aanvallen en beschermingen benoemd.

Database aanvallen

Databases kunnen net als ieder ander systeem aangevallen worden door wachtwoord kracking of server overloads maar er is een techniek die specifiek werkt op slecht beveiligde databases en dat is database/SQL injections.

Hierbij maakt de hacker gebruik van een zoek invoer veld en plaatst daarin een stuk SQL code die uitgevoerd kan worden. De invoer kan zijn voor het opvragen van data tot het veranderen of verwijderen ervan. Deze techniek is zeer makkelijk uit te voeren met minimale kennis maar is zeer makkelijk traceerbaar. De lichtste straf zou zijn dat je IP adres een ban heeft van de applicatie/service/website maar de straffen kunnen oplopen tot 20 jaar celstraf.

Veel applicaties en websites hebben een SQL injection controle tool op de invoer velden zitten zodat het opgevangen wordt. Deze controles maken dan ook gelijk een melding bij de beheerder en die kan dan actie ondernemen indien nodig.

Database beschermingen

Om een database te beveiligen zijn enkele opties mogelijk, de simpelste is om een sterk wachtwoord te plaatsen op de database zodat deze niet gehackt kan worden, echter als je applicatie lokaal moet runnen op je klanten hun hardware dan wordt dat wachtwoord gedeeld en is dus niet veilig meer.

Om dit te verhelpen kan je meerdere rollen aanmaken op een database deze rollen kunnen rechten krijgen om gebruik te maken van specifieke databases en tabellen. Zo kan je een gebruiker wel veilig inzicht geven in de gebruikersnamen maar de wachtwoorden en e-mails veilig houden.

Een andere recht zit in de CRUD beveiliging. Hierin kan je per rol per tabel aangeven of ze een item mogen aanmaken (Create), lezen (Read), aanpassen (Update) en verwijderen (Delete). Door de rol allen te laten lezen en aanmaken kan je voorkomen dat data corrupt raakt of verdwijnt.

Het laatste aan rechten dat je kan doen is een download blokkade opstellen, dit is een tabel recht waarbij de gebruiker de data niet in een bestand kan downloaden. Dit is om te voorkomen dat datalekken heel snel uit de hand lopen.

Om ervoor te zorgen dat deze rechten niet misbruikt worden zijn er vaak systeem beheerders die de database monitoren. Een extra beveiliging voor data kan ook zijn om een back-up database te hebben die elke dag de originele database kopieert om zo te voorkomen dat verlies van data een groot probleem wordt aangezien een groot deel van bedrijven dat hun data verliest door een cyber aanval binnen een jaar of 2 failliet gaat.

4. Cyber wetgeving en criminaliteit

Wetgeving en criminaliteit bestaan op elk werkveld, zeker binnen de IT-wereld. De eerste geschreven wetten zijn meer dan 3000 jaar oud, in vergelijking zijn de Cyber wetten relatief jong met de oudste cyber wet die was opgezet in 1986. Een van de problemen met cyber wetgeving is dat de wetgeving vaak achter loopt op de technologie en er moeten vaak eerst incidenten voorkomen voordat de wetgeving wordt opgezet.

Binnen dit hoofdstuk worden de grootste en belangrijkste wetten op verschillende niveaus behandeld, van het internationaal niveau tot aan het Nederlands niveau. Er wordt ook gekeken naar de wetgevingen van 2 van de grootste IT spelers in de wereld met Chinese en Amerikaanse wetten. Verder word er een kleine introductie gegeven op het gebied van cyber criminaliteit om inzicht te geven op de diverse criminele stromen.

4.1. Internationale wetgeving

Het merendeel van de cyber wetten die zijn opgesteld zijn gemaakt door een van twee instanties: De VN (verenigde naties) of het ICC (International criminal court) en worden meestal gehandhaafd door de landen zelf via hun geheime diensten of door Interpol als het wereldwijd van toepassing is. Veel van deze internationale wetten zijn opgezet tussen 2000 en 2017 met 1 wet die in overleg is sinds 2024 maar recentelijk op stop is gezet.

Het merendeel van de internationale wetten draaien rondom Globale zaken waarvan (het merendeel van) de wereld zegt dat dit tegen gegaan moet worden. Denk hierbij aan:

- Het recht van bestaan van ieder land op het internet (Denk aan IP landcodes en het recht van een eigen url afsluiting zoals .nl, .be en .uk)
- Het bevechten van cyber criminaliteit in het algemeen
- Wetten tegen kinderporno en seksuele mishandeling
- Een algemene wetgeving tegen racisme, seksisme en nauwe samenwerking tussen de landen

Hoewel deze wetten bestaan en er enige handhaving is, vormen deze wetten eerder een richtlijn dan daadwerkelijke wetten en moeten het merendeel van de landen er zelf uitkomen hoe ze dit aanpakken.

4.1.1. Budapest conventie – The gold standard

De belangrijkste wet vanuit de VN is de Budapest conventie. Origineel een wetgeving bedacht in Europa maar is later de Goude standaard van internet wetgeving geworden. De conventie is ondertekend in 2001 door de westerse landen, aangepast in 2003 en in 2022 si de meest recente versie ondertekend door meer landen.

De conventie bevat vele regels rondom samenwerking tegen cyber criminaliteit, een opzet van hoe wetgeving, criminaliteit en bewijs geregeld kan worden rondom cyber criminaliteit en wetten tegen:

- Racisme
- Fraude
- Privacy inbreuk
- Hacking
- Kinderporno
- Spyware,
- illegaal zoeken door politie of regering
- Veel meer

Een van de grootste kritiek punten die zijn gemaakt in de afgelopen 25 jaar is dat de westerse landen geen input hebben gevraagd van de niet-westerse landen en dat dit vooral merkbaar is rondom de wetten van hoe regeringen die tegen over elkaar staan mogen handelen.

Een poging tot een aanpassing in 2019 door Rusland zou de taal vaag maken zodat er in sommige situaties zoals bij verdenking van cyber criminaliteit een andere regering bespioneerd mag worden en data verzameld kan worden. Deze aanpassing is tot op heden niet volledig doorgevoerd. Grote spelers zoals India, Rusland en China hebben tot op heden de Budapest conventie niet ondertekend.

4.2. Europese wetgeving

Europa en de Europese commissie is een meester in regulatie, zeker op het gebied van cyber criminaliteit en veiligheid. Het merendeel van de wetten die zijn opgezet op het Europees niveau worden eerst voorgedragen door de commissie of door een land. Dit wordt dan besproken met de EU in het groot. De achterban (of te wel de lokale regeringen) kunnen daarna meewegen hierover. Daarna komt de EU weer bijeen voor een vergadering om de wet te bespreken en eventuele aanpassingen voor te stellen. Dit blijft herhalen tot het wordt aangenomen als wet. Daarna is er vaak een 2 tot 5-jarige periode waarin de landen de wet moeten invoeren. De Europese wetten kunnen om deze reden soms 10 jaar duren voordat ze geïmplementeerd worden.

Europa heeft een vergelijkbaar probleem als de VN op het gebied van handhaving, Europa moet erop vertrouwen dat landen zelf de handhaving regelen of in ernstige gevallen Europol inschakelen.

De Europese wetten zijn in vergelijking met de internationale wetten vaak specifieker en leiden vaak tot veranderingen wereldwijd. Zo zijn NIS2 en AVG in meer dan alleen de Europese landen toegepast en de DSA en DMA ook in enkele westerse landen van toepassing.

4.2.1. NIS2 - Netwerk and information security directive

Dit is een cyber weerbaarheidswet om ervoor te zorgen dat regeringen, bedrijven en inwoners ondersteund en beschermd. De NIS2 zorgt ervoor dat bedrijven en regeringen een zorgplicht hebben. Zo mogen sommige instanties bepaalde gegevens niet vragen en bewaren tot ze een bepaalde veiligheidsstandaarden hebben behaald. Dit wordt onder andere gedaan door een risico analyse uit te voeren en door veiligheidsinspecties van onder andere de regering.

Bedrijven en instanties hebben ook een meldplicht door deze wet. Binnen 24 uur moet een incident van dataleks en hackers gemeld worden bij de regering/media/gebruikers. Hierna wordt de schade bepaald en wordt er samen met de lokale regering bepaald wat er aan schade herstel gedaan moet worden. Bedrijven/instanties die zich niet houden aan het meldplicht kunnen hoge boetes op lopen. Dit hoort bij het derde deel van de NIS2, aansprakelijkheid. Bedrijven en bestuurders moeten aansprakelijk gehouden kunnen worden voor slechte cyber veiligheid van personeel en klanten.

4.2.2. GDPR/AVG – General data protection regulation/Algemene verordening gegevensbescherming

De AVG, ook bekend als de GDPR, is een standaardiseringswet en een gebruikers beschermingswet in een. De AVG standaardiseert privacy en data wetten over heel Europa en zorgt ervoor dat de gegevens van Europese inwoners verantwoord en geïnformeerd hun data delen met bedrijven.

Op het gebied van standaardiseren help het voor bedrijven om een norm te hebben over de gehele EU zodat ze geen tientallen versies moeten hebben van software die aan allerlei eisen voldoen. Voor de gebruikers zorgt het ervoor dat als een bedrijf zich hier niet aan houdt in een ander Europees land, ze alsnog berecht worden onder dezelfde wetten.

De AVG zorgt er ook voor dat EU bewoners geïnformeerd toestemming moeten geven over het delen van data naar derde bedrijven en moeten bedrijven aan de EU verantwoorden waarom ze bepaalde gegevens van EU bewoners nodig achten om te verzamelen. Denk hierbij aan BSN nummer, ID/paspoort foto's en bankrekeningnummers. Indien de EU dit goed keurt wordt er een beveiligingsstandaard geëist voordat het in werking komt.

4.2.3. DSA – Digital services act

Het doel van de Digital services act is om bepaalde diensten te regulieren zodat schadelijke inhoud of misbruik van gegevens voorkomen kan worden. Denk hierbij aan het beschermen van gebruikers tegen illegale posts op social media, het transparant maken van algoritmes die content voor gebruikers zet, reclames regels opzet en competitie tussen bedrijven waarborgt.

De DSA zorgt er ook voor dat bepaalde inhoud niet getoond mag worden en direct verwijderd moet worden door moderatie teams. Denk hierbij aan Kinderporno, Racisme, seksisme, antisemitisme en aanmoedigen van seksueel geweld of zelfmoord.

De DSA is continu in ontwikkeling en recentelijk zijn veel Amerikaanse bedrijven tegen de DSA om diverse redenen.

4.2.4. DMA – Digital markets act

De DMA is vergelijkbaar met de DSA en wordt vaak verward. Beide van deze wetten beschermen de competitie tussen bedrijven, echter gaat de DMA verder dan de DSA. De DMA beschermt kleinere bedrijven tegen oneerlijke handel van grote bedrijven zoals Microsoft en Google. Denk hierbij aan een kleine zoekmachine die niet omhoog komt als er direct via google naar gezocht wordt of een tekstverwerkingsapplicatie die wordt geblokkeerd door Windows.

4.2.5. Recente wetten en wetsvoorstellen

De DSA is recent meer in het nieuws doordat de toevoeging van leeftijdsverificatie en een sociaal media verbod op tafel liggen bij de commissie. Een ander initiatief is tijdelijk in het nieuws geweest waarbij er een verzoek is gekomen om game bedrijven verantwoordelijk te houden voor het stop zetten van live service games zonder tools om het door te zetten vanuit de klanten, ook wel bekend als "Stop killing games".

4.2.5.1. EU AI act

Met het toenemend gebruik is er ook een EU wet in optreden die in fases toegepast wordt om AI in te kaarten en mensen te beschermen tegen de negatieve effecten. Denk hierbij aan vangnetten voor illegale inhoud, bescherming van copyright en tegen misinformatie. De wet is binnenkort in de laatste fase en er wordt verwacht dat er aanvullingen zullen komen aangezien de AI technologie zich zeer snel ontwikkeld. Toen de wetten werden opgesteld was er nog weinig sprake van video genererende AI laat staan AI die reclames gebruikt om winst te drijven of AI die kinderporno ontwikkeld. Over de komende 5 jaar zullen er meer wetsvoorstellen naar voren worden gebracht en enkele zullen effect hebben op hoe AI wordt toegepast in Nederland.

4.3. Nederlandse wetgeving

Omdat Nederland in de Europese unie zit zijn vele van de wetten hetzelfde, echter zijn er enkele uitzonderingen zoals de wet computercriminaliteit 3 en de kansspelwetgeving.

4.3.1. Wet Computercriminaliteit III

Deze wet gaat verder dan de NIS2 en AVG en geeft de politie en geheime dienst de mogelijkheid om zelf in computers te hacken van verdachte criminelen op te sporen en bewijs te vinden. Deze toestemming moet gegeven worden door een rechter

4.3.2. Kansspelwetgeving

De kansspelwetgeving is een wet die over heel Europa wordt toegepast maar Nederland en België passen deze strenger aan. Zo zijn enkele games met Lootboxes verboden en in onderzoek om te bepalen of ze vallen onder gokspellen gericht op kinderen. In België is het al verboden maar in Nederland is het nog niet concreet gemaakt.

4.4. Amerikaanse wetgeving

De Amerikaanse markt is een van de leiders in ontwikkeling en gebruik van IT systemen. Dit betekent dat een groot deel van de IT systemen in de wereld zich houden aan de Amerikaanse wetten. Amerikaanse wetten leggen vaak eerst vast wat de regering wel en niet mag doen voordat ze naar bedrijven kijken. Dit is merkbaar aan hoe HIPAA en FISMA zijn geformuleerd, in het grote schaal is dit ook van belang voor de Amerikaanse bevolking echter is de intentie verschillend met dat van de wetten in de Europese unie. De volgende wetten zijn vooral belangrijk om kennis van te hebben.

4.4.1. HIPAA

HIPAA is een wet die origineel gefocust is rondom de zorg en gegevens van medische patiënten maar is deels uitgebreid naar cruciale bedrijven waarvan persoonsgegevens beschermd moeten zijn. HIPAA heeft concrete afspraken rondom encryptie, firewalls, toegangsverlening en communicatie netwerken op het technisch vlak. Fysiek zijn er ook regels rondom de sloten op deuren, wie toegang heeft tot welk deel van het netwerk en welke controles er uitgevoerd moeten worden op leidinggevenden.

4.4.2. FISMA

FISMA is de NIS2 van de Amerikaanse regering, veel van de wetten zijn hier in overgenomen met enkele uitzonderingen. FISMA is vooral gefocust op de Amerikaanse regering en de ontwikkelaars die ze in huren voor hun systemen. Om deze te begeleiden naar veilige systemen moeten ze voldoen aan de NIST standaard, hierin staan de eisen rondom de diverse beveiligingen en waarborging. Een ander verschil tussen FISMA en de NIS2 is dat FISMA vereist dat er binnen 48 uur melding gemaakt wordt van datalekken en hackers ten opzichte van de 24 uur van de NIS2.

4.4.3. NIST Cybersecurity

De NIST framework is een opzet van processen en controles om de beveiliging van applicaties op orde te zetten. Hierbij zitten er standaarden aan beveiligingsniveaus, de plannen voor bescherming, reacties, en herstel rondom cyber aanvallen. De NIST vormt een template voor alle grote Amerikaanse applicaties die gebruik willen maken van persoonsgegevens en wordt als eis gesteld voor regering applicaties.

Recentelijk zijn bij de NIST enkele uitbreidingen toegevoegd om AI en IOT te ondersteunen en mensen te beschermen tegen privacy inbreuk.

4.5. Chinese wetgeving

China is net als Amerika een van de grootste consumenten en ontwikkelaars op het gebied van IT en systemen. Dit heeft als effect dat de Chinese wetgevingen vaak meegenomen kunnen worden in het ontwerp van een wereldwijde applicatie. Hoewel China vele Europese wetten en standaarden heeft overgenomen om mee te kunnen doen aan de Europese markt zijn de standaarden vaak gewijzigd om een voordeel te geven aan overheidsinstanties. Ook heeft China meer wetten rondom bepaalde concepten en beroepen die verder gaan dan de Europese unie.

4.5.1. PIPL

PIPL is de GDPR wet van China, hierin staat wat bedrijven wel en niet mogen bewaren en dat ze de gebruik geïnformeerd toestemming moeten vragen over de data die ze willen gebruiken met derde partijen. Veel van deze wet legt de focus op hoe de overheid omgaat met de persoonsgegevens van de Chinese bevolking en minder op de bedrijven echter zijn deze ook meegenomen in de wet. Zo moeten bedrijven om 3 toestemmingen vragen van de gebruikers om data te verzamelen en gebruiken. 1 voor de data verzameling, 1 voor het doorgeven aan Chinese derde bedrijven en 1 voor ieder buitenlands bedrijf.

Een ander verschil is dat er delen van wetten vaag zijn gehouden om de Chinese regering de mogelijkheid te geven om de data in te kunnen zien.

Het laatste opmerkelijke verschil tussen de GDPR en PIPL is dat PIPL voor een datalek of hacking er geen deadline is om een melding te maken bij autoriteiten.

4.5.2. CSL

De CSL is een cyber security law die vele elementen van cyber criminaliteit definieert, bestraft en weert door processen op te zetten om beveiliging te verscherpen. Veel van de wetten binnen de CSL zijn vergelijkbaar met die van Amerika en de EU maar er zijn twee delen die opmerkelijk zijn. Data lokalisatie is een belangrijk begrip in China waar er een eis is dat data van Chinese inwoners in China opgeslagen moet worden. Het andere opmerkelijke aspect is dat China bedrijven en applicaties kan verbieden met deze wet als er buitenlandse regeringen deel hebben genomen in de ontwikkeling ervan en daardoor invloed kunnen uitoefenen op de bevolking van China.

4.5.3. Crypto verbod

China heeft vanaf 2012 een verbod op crypto munten en trading, dit geldt voor alles van bitcoin tot Dogecoin. Dit betekent niet dat er in China geen Cryptomining gedaan wordt echter is het wel verboden en hangen er zware celstraffen op. Dit betekent dat als er een financiële app gebouwd moet worden waar ook crypto in verwerkt zit dit uit moet staan binnen de Chinese grenzen.

4.5.4. Influencer verbod

China heeft als weinige een influencer verbod op bepaalde thema's gezet om zo de populatie te beschermen. De thema's zijn: Financiën, Rechten, medicijnen en politiek. Dit is om de bevolking te beschermen tegen nep nieuws en foutieve informatie. Het is technisch gezien nog wel mogelijk om een influencer te worden op deze gebieden, echter moet hier een speciaal certificaat voor gehaald worden die bewijst dat je weet waar je het over zou hebben.

Dit kan effect hebben op een social media app waarin gecontroleerd moet worden of de persoon in kwestie daadwerkelijk een certificaat heeft.

4.5.5. Verbondenheid met overheid

Er zijn enkele wetten die de Chinese overheid heeft staan die ervoor zorgen dat bedrijven binnen China nauw verbonden moeten samenwerken met de overheid. Dit is deels omdat de Chinese tech-industrie veel subsidie krijgt van de overheid maar ook deels voor controle. De Chinese overheid kan volgens enkele Chinese wetten ook data opvragen zonder bevel over gebruikers, zowel eigen inwoners als inwoners van andere landen. Of dit positief uitpakt voor de gebruiker is open tot discussie.

4.6. Contract types binnen de IT

Er zijn vele contracten die binnen de IT wereld van toepassing kunnen zijn en een algemeen begrip hebben van de types is zeer belangrijk. Algemeen advies is om contracten goed door te lezen en in geval van twijfel vraag om juridisch advies van een gekwalificeerd advocaat op het gebied van contracten.

4.6.1. NDA – Non-disclosure agreement

Een NDA is een contract waarbij er afspraken zijn gemaakt over wat er wel en niet overlegd mag worden over een project of onderwerp. Dit is vaak van toepassing als er gevoelige informatie van toepassing is, bijvoorbeeld bij defensie of een medisch centrum. NDA's kunnen heel specifiek zijn waardoor de algoritmes van een systeem niet besproken mogen worden of heel breed waardoor zelf het noemen dat je deel uit maakte van een project bij bedrijf X niet mag. Bijna alle NDA's worden gebonden aan een tijdsframe en het is niet ongewoon dat het tekenen van een NDA samen komt met een extra bonus voor de werknemer.

Realiseer je wel dat een NDA niet boven de wet staat, als bedrijf X je een NDA laat tekenen en vervolgens illegaal bezig is dan is je plicht dit te melden.

4.6.2. NCA – Non-compete agreement

Een NCA is een contract waarbij wordt gezegd dat als je ontslagen wordt of ontslag neemt bij een bedrijf dat je dan niet bij de competitie gaat werken. Dit is om te voorkomen dat je een systeem opzet, hiervoor betaald wordt en dan ontslag neemt en hetzelfde systeem bij de competitie gaat opzetten. Het helpt ook tegen het doorspelen van bedrijfsgeheimen en klant contacten die je opbouwt over je werkperiode. NCA's mogen niet gesteld worden over gehele branches zoals IT maar wel over specifieke sectoren zoals Mobile apps development voor financiën. Een NCA is gewoonlijk 5 tot 10 jaar maar komt vaak ook met een bonus voor ondertekenen. Lees echter goed dit contract door en overweeg het aangezien slechte verwoording ervoor kan zorgen dat je bijna nergens meer kan werken.

4.6.3. MSA – Maintenance and support agreement

De MSA is een afspraak voor een bepaalde tijd waarin je als ontwikkelaar onderhoud moet uitvoeren en support moet leveren over het afgeleverde product. Denk hierbij aan de code aanpassen als er een nieuwe Windows update komt of support moet geven als je robots batterij vervangen moet worden. Je bent dan niet meer in loondienst en in sommige gevallen word je er niet meer voor betaald. Deze contracten komen vaak voor tussen bedrijven onderling of als freelancer tegenover een klant. Voor dit soort contracten wordt meestal meer bij ontwikkeling betaald of word er een kleine betaling maandelijks gemaakt.

4.6.4. SDA –software development agreement

De SDA of ook vaak het Plan van aanpak genoemd is een afspraken document tussen een klant en ontwikkelaar waarin alle eisen, wensen, meetmomenten en benchmarks staan omschreven. Dit document onderhoudt de eisen zodat de klant geen extra eisen kan bij verzinnen bij oplevering om zo onder betalen uit te komen maar zorgt er ook voor dat de ontwikkelaars daadwerkelijk afleveren wat gevraagd is van ze. Deze contracten zijn vaak lang en bevatten veel technische ontwerpen. Deze contracten worden vaak ook bijgesteld indien beide partijen hier mee in orde zijn. Lees deze goed door en overleg het eerst met je team voordat je het aanneemt, klanten kunnen geniepig zijn en dit document bepaald of je als freelancer betaald wordt of niet.

4.6.5. SLA – Software license agreement

De SLA is een document waarin staat of en hoe een bepaalde software gebruikt mag worden door welke partij. Dit gaat dan om specifieke software die al ontwikkeld is maar die door een bedrijf gebruikt moet worden. Deze overeenkomsten zijn vergelijkbaar met een huurcontract waarbij een periode wordt bepaald waarin maandelijks betaald wordt voor het gebruik.

4.6.6. EULA – end user license agreement

De EULA beschrijft de gebruikers intenties en dat de systemen niet eigendom zijn van de gebruiker. Het geeft aan dat de gebruiker als het waren een gast in en een licentie gebruikt in plaats van eigenaar zijn van de software. Dit betekent dat onder voorwaarde de ontwikkelaar toegang tot het systeem kan blokkeren indien er een actie is geweest die als verboden staat beschreven in de EULA. Verschillende ontwikkelaars stoppen deze vol met juridische termen en maken deze heel uitgebreid en recent zijn er termen toegevoegd aan diverse programma's (waar onder andere games) die aangeven dat gebruikers zonder reden geblokkeerd kunnen worden van toegang.

Enkele (vooral game) bedrijven stoppen er ook leuke eastereggs in zoals Larian studios omdat ze ervan uit gaan dat niemand het contract daadwerkelijk leest.

4.6.7. AUP – Acceptable use policies

De AUP is een soort van vervolg van de EULA waarbij de gedragsregels vaak gespecificeerd worden rondom hacker gedrag en misbruik van een systeem voor kwade doeleindes.

4.6.8. T&C – Terms and conditions

De terms en conditions is een document en contract waarin staat hoe de applicaties gebruikt hoort te worden, wat de gebruiker moet bieden om het werkend te houden van de app. Hier staat onder andere ook in welke randvoorwaarde de app nodig heeft, denk aan besturingssysteem, ondersteunende software en een afspraak rondom gebruik en delen ervan.

Vaak worden hier ook gedragsregels en eventuele straffen vermeld tegen misbruik van het systeem.

4.6.9. Privacy policy

Dit document beschrijft hoe de applicatie gebruik maakt van data en welke verzameld wordt. Dit document moet vaak geaccepteerd worden om een applicatie te gebruiken maar geeft details af over hoe je persoons informatie gebruikt wordt. Veel van deze documenten worden gevuld met onnodige taal en verstoppen clausules over dat gegevens gedeeld mogen worden en verkocht worden door het bedrijf.

4.6. Cyber criminaliteit

Cyber criminaliteit is net als reguliere criminaliteit, er zijn kleine incidenten, gerichte acties, goedbedoelde initiatieven, cyber aanslagen en spionage. De kern hierbij is dat dit allemaal uitgevoerd wordt op het internet en binnen IT systemen.

Binnen Cyber criminelen zijn er een aantal subgroepen die belangrijk zijn om uit te lichten van laag tot hoog niveau.

4.6.1. Script kiddies en “Green” hackers

Script kiddies en “green” hackers zijn beide onervaren beginnende hackers die nog leren omgaan met een systeem en hoe ze aanvallen moeten uitvoeren. Het hoofd verschil tussen de twee is dat “green” hackers alleen proberen te hacken op systemen waar ze toestemming van hebben zoals sites als Hackthissite. Script kiddies proberen hun skills uit op elke systeem dat ze maar willen. In sommige gevallen worden script kiddies met een waarschuwing vrijgelaten maar in de meeste gevallen wordt er een taakstraf, boete of zelfs gevangenis straffen opgelegd.

4.6.2. Gray hackers

Gray hackers bevinden zich in een grijs gebied omdat de acties die ze uitvoeren vaak zonder toestemming zijn gedaan maar er wordt pas actie ondernomen als een hacker persoonlijk belang heeft bij het hacken van een systeem. Bijvoorbeeld: een gray hacker kan in een systeem breken en dan de eigenaar uitleggen hoe het gebeurde en ze adviseren hoe ze dat kunnen voorkomen. Dit wordt gezien als goed gedrag ondanks het breken van wetten. In tegenstelling een gray hacker die vraagt om geld om de zwaktes toe te lichten kan worden gezien als afpersing.

4.6.3. Blue (collar) hackers

De bedrijfshacker, blue hackers worden ingehuurd door bedrijven om de beveiliging van een applicatie te testen voordat deze beschikbaar wordt voor klanten. Deze hackers geven dan een rapport af met gedetailleerde omschrijvingen van hoe ze binnen zijn gekomen, wat ze konden doen en hoe het verbeterd kan worden.

4.6.4. White en Red hackers

White en red hackers komen op hetzelfde neer met enkele kleine verschillen. Beide hackers worden gezien als counter-hackers en beschermen systemen tegen misbruik en hackers. Dit zijn specialisten die door bedrijven en regeringen gebruikt worden, met red hackers die enkel voor regeringen werken. Dit zijn meestal enkele van de beste hackers die er zijn.

4.6.5. Hackivisten

Hackivisten zijn activisten die voor een of ander doel besluiten om systemen plat te leggen of over te nemen. Dit kunnen voor goede, neutrale of slechte doeleindes zijn. Er zijn enkele groepen die gebruik maken van cyber criminaliteit om de wereld beter te maken in vergelijkbare wijze zoals green peace. Andere groepen treden enkel op als er grote momenten zijn op het wereld toneel, denk aan Anonymous die de Kremlin website tijdelijk heeft overgenomen gedurende het begin van de oorlog met Oekraïne.

4.6.6. Zwarte hackers

Zwarte hackers zijn de reden dat counter hackers nodig zijn. Dit zijn cyber criminelen die inbreken in een systeem zonder toestemming en vervolgens een van de volgende acties uitvoeren:

- Data stelen
- Afluisteren van communicatie
- Systemen blootleggen (zwakheden introduceren in een systeem)
- Ransomware installeren
- Virussen plaatsen
- Overname van systemen

Zwarte hackers zijn criminelen die vaak niet gekoppeld zijn aan landen, regeringen of grootschalige groepen maar vooral uit zijn op geld verdienen door in te breken.

4.6.7. Cyber terroristen

Cyber terroristen worden soms betaald door regeringen om andere landen schade aan te doen of doen dit uit eigen initiatief. Deze hackers breken niet in een systeem om data te stelen of om losgeld te vragen, ze breken in om systemen te breken en om gehele bedrijven stop te zetten. Enkele voorbeelden zijn hoe ziekenhuizen, gemeentes, verkeer en elektriciteit centrales voor langere periodes plat gelegd werden in de afgelopen 5 jaar. Dit kan een groot effect hebben op mensen hun levens en het functioneren van een land.

Bronnen en afbeeldinglinks

https://www.geeksforgeeks.org/computer-networks/difference-between-rsa-algorithm-and-dsa/

Handige studie links en video's

NIS2 uitleg video:

https://www.youtube.com/watch?v=Jdkl_Y6yRJ8

AVG uitleg video:

https://www.youtube.com/watch?v=yn74wGfJ-z8

EU AI act uitelg video:

https://www.youtube.com/watch?v=oWHCyLfUgUw